

ENTERPRISE INFORMATION SECURITY & COMPLIANCE POLICY

Policy ID: POL-SEC-2026-v4.2 | Effective Date: 2026-02-01 | Classification: Confidential Internal

1. Scope and Regulatory Applicability

This standard governs all production information systems, cloud tenancies, employee workstations, and third-party data handlers. It implements compliance mandates aligned with **ISO/IEC 27001**, **SOC 2 Type II**, **GDPR**, and **NIST CSF v2.0**.

2. Mandatory Cryptographic and Access Controls

- **Encryption at Rest:** All databases, object storage buckets, and document repositories must utilize AES-256 encryption with managed HSM key rotation every 90 days.
- **Encryption in Transit:** TLS 1.3 is strictly enforced on all public and internal service mesh endpoints with cipher suites offering perfect forward secrecy.
- **Multi-Factor Authentication:** FIDO2/WebAuthn hardware tokens are mandatory for all administrative access.

3. Data Retention and Audit Logging

Immutable security audit logs must be retained for a statutory minimum of 365 days. Access logs must record timestamp, user identifier, IP address, and requested action.

4. Incident Response & Non-Compliance Penalties

Suspected data disclosures or security anomalies must be reported to the Security Operations Center (soc@enterprise.internal) within 60 minutes. Failure to comply with security standards constitutes gross negligence and may result in immediate termination of employment or commercial contract termination.